



Tarea #1

Contacto con metodologías de Seguridad

Profesor:

Dedaniel Urribarri

Elaborado por:

Luisdavid Colina V24766381

Fecha de solicitud: 30 de abril del 2026

Fecha de Entrega: 06 de mayo 2026



Conceptos a Investigar

Pentesting y Análisis de Vulnerabilidades

El Análisis de Vulnerabilidades es un proceso sistemático diseñado para identificar, cuantificar y priorizar las debilidades en un sistema, aplicación o infraestructura de red [1]. Su objetivo primordial es proporcionar una visión clara del estado de riesgo sin necesariamente ejecutar la explotación de los fallos encontrados. Generalmente, se apoya en herramientas automatizadas (escáneres) que contrastan la configuración del objetivo con bases de datos de vulnerabilidades conocidas como CVE (Common Vulnerabilities and Exposures).

Por otro lado, el Pentesting (o Pruebas de Penetración) es una metodología activa que simula un ataque real realizado por un agente malintencionado [2]. A diferencia del análisis de vulnerabilidades, el pentesting busca explotar activamente las debilidades para evaluar el impacto real y la profundidad de la intrusión posible. Este proceso se divide habitualmente en fases de reconocimiento, escaneo, ganancia de acceso, mantenimiento de acceso y borrado de huellas [2].

Hardening (Endurecimiento de Sistemas)

El Hardening se define como el conjunto de procesos y herramientas destinados a reducir la superficie de ataque de un sistema informático [3]. Esta metodología implica la eliminación de servicios innecesarios, el cierre de puertos no utilizados, la gestión estricta de privilegios de usuario y la aplicación de parches de seguridad actualizados.

El principio fundamental del hardening es el mínimo privilegio, donde cada componente del sistema opera únicamente con los recursos estrictamente necesarios para su función [3]. Se implementa a diferentes niveles: sistema operativo, aplicaciones, bases de datos y dispositivos de red, siguiendo guías de mejores prácticas como los CIS Benchmarks.

Análisis de Código: Estático y Dinámico

El Static Application Security Testing (SAST) consiste en la revisión del código fuente, binarios o archivos de configuración sin ejecutar la aplicación [4]. Permite identificar errores lógicos, vulnerabilidades de inyección y malas prácticas de programación de forma temprana en el Ciclo de Vida de Desarrollo de Software (SDLC). Al ser una inspección "de caja blanca", ofrece una visibilidad total de la estructura interna del programa.



El Dynamic Application Security Testing (DAST) analiza la aplicación durante su ejecución, interactuando con ella desde el exterior [5]. Es una metodología de "caja negra" que identifica fallos de seguridad que solo se manifiestan en tiempo de ejecución, como problemas de gestión de sesiones, configuraciones de servidor incorrectas o fallos de autenticación. A diferencia del SAST, el DAST no tiene acceso al código fuente original, enfocándose en cómo responde la aplicación ante estímulos externos.

Conclusiones

En el contexto de nuestra primera aproximación a la seguridad, fue primario comprender que estas herramientas investigadas forman un ciclo de protección integral: mientras que el Análisis de Código (Estático y Dinámico) asegura que las aplicaciones nazcan con una base sólida y el Hardening reduce los puntos de entrada al "limpiar" y configurar correctamente los sistemas [3], [4], el Análisis de Vulnerabilidades y el Pentesting actúan como mecanismos de verificación constante que ponen a prueba la eficacia de esas defensas previas bajo condiciones de ataque simulado [1], [2]. Esta combinación permite que la red no solo sea segura por configuración, sino también resiliente ante el software defectuoso y las amenazas externas.

Referencias

- [1] K. Scarfone and M. Souppaya, "Technical Guide to Information Security Testing and Assessment," NIST Special Publication 800-115, National Institute of Standards and Technology, 2008.
- [2] EC-Council, "Certified Ethical Hacker (CEH) Version 11 Study Guide," Wiley, 2021.
- [3] Center for Internet Security (CIS), "CIS Controls Version 8: A Prioritized Set of Actions for Cyber Defense," CIS Security, 2021.
- [4] OWASP Foundation, "Static Code Analysis," [En línea]. Disponible: https://owasp.org/www-community/controls/Static_Code_Analysis. [Acces: 07-may-2026].
- [5] B. Chess and J. West, "Secure Programming with Static Analysis," Addison-Wesley Professional, 2007.